

1-Introduction

This report presents an analysis of **Active Directory Domain Services Privilege Escalation (CVE-2025-21293)**, focusing on understanding, exploiting, and mitigating this vulnerability in a controlled lab environment.

The assessment follows industry-standard methodologies, including:

- **NIST SP 800-30** (Risk Management Guide for Information Systems)
- **MITRE ATT&CK Framework** (For understanding attacker techniques)
- **OWASP Testing Guide** (For security testing best practices)

The primary objective of this study is to:

- ✓ Set up a virtual lab for safe testing
- ✓ Explore publicly available Proof-of-Concept (PoC) exploits
- ✓ Demonstrate the attack process and privilege escalation techniques
- ✓ Analyze security defenses and recommend mitigation strategies

This report provides a structured approach to understanding real-world exploitation techniques and improving cybersecurity resilience.

2-Environment Setup

For this project, a virtual lab is created using **VirtualBox** with the following setup:

- **Attacker Machine:** Kali Linux
- **Victim Machine:** Windows 7

1. Virtual Machine Setup

- **Kali Linux:** Installed using the latest ISO from kali.org, with essential tools like **Metasploit**, **Impacket**, and **Evil-WinRM**.
- **Windows 7:** Configured as the target system with a standard user account.

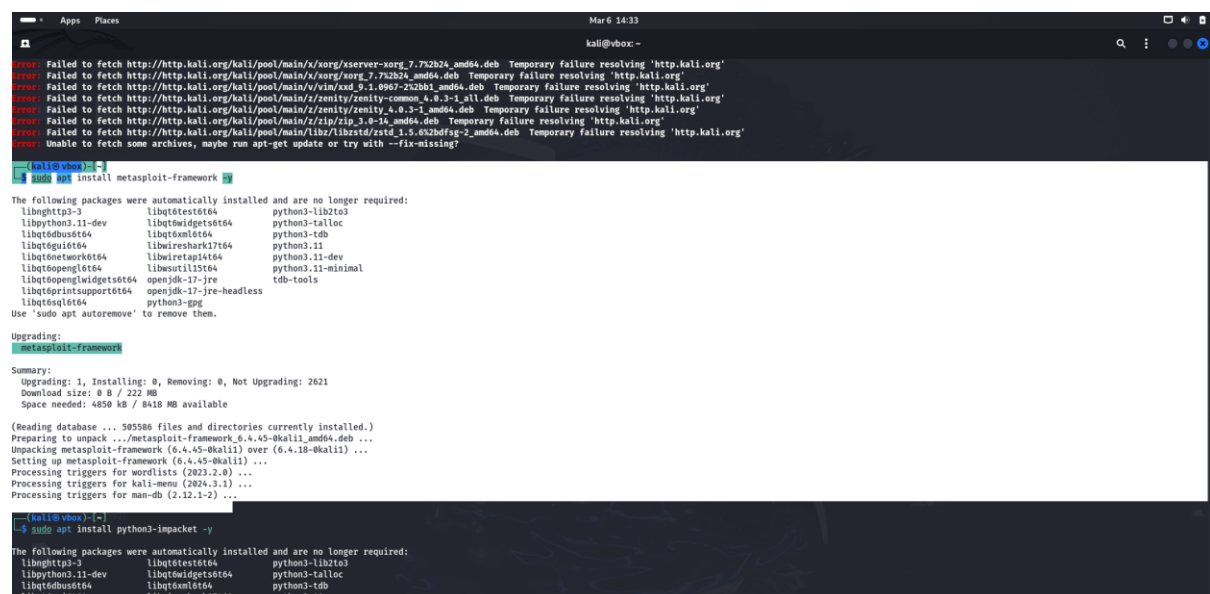
2. Network Configuration

- Both VMs are connected using a **Host-Only Adapter** to enable direct communication.
- IP addresses are verified using ifconfig (Linux) and ipconfig (Windows).

3. Final Verification

- ✓ Both VMs are installed and updated.
- ✓ Network connectivity between VMs is confirmed.
- ✓ Security tools are set up in Kali Linux.

This environment will be used to test and exploit vulnerabilities safely.



```
Mar 6 14:33
kali@vbox: ~
$ sudo apt install metasploit-framework
The following packages were automatically installed and are no longer required:
libnghttp3-3 libqt6testqt6 python3-lib2to3
libpython3.11-dev libqt6widgets6 python3-talloc
libqt6dbus6 libqt6xml6 python3-tdb
libqt6gui6 libwireshark17t64 python3.11
libqt6network6 libwireshark17t64 python3.11-dev
libqt6opengl6 libwireshark17t64 python3.11-minimal
libqt6openglwidgets6 openjdk-17-jre tdb-tools
libqt6printsupport6 openjdk-17-jre-headless
libqt6sql6 python3-gpg
Use 'sudo apt autoremove' to remove them.

Upgrading:
metasploit-framework

Summary:
Upgrading: 1, Installing: 0, Removing: 0, Not Upgrading: 2621
Download size: 0 B / 222 MB
Space needed: 4850 kB / 8418 MB available

(Reading database ... 505586 files and directories currently installed.)
Preparing to unpack .../metasploit-framework_6.4.45-0kali1_amd64.deb ...
Unpacking metasploit-framework (6.4.45-0kali1) over (6.4.18-0kali1) ...
Setting up metasploit-framework (6.4.45-0kali1) ...
Processing triggers for wordlists (2023.2.0) ...
Processing triggers for kali-menu (2024.3.1) ...
Processing triggers for man-db (2.12.1-2) ...

kali@vbox: ~
$ sudo apt install python3-impacket -y
The following packages were automatically installed and are no longer required:
libnghttp3-3 libqt6testqt6 python3-lib2to3
libpython3.11-dev libqt6widgets6 python3-talloc
libqt6dbus6 libqt6xml6 python3-tdb
libqt6gui6 libwireshark17t64 python3.11
```

```
Mar 6 14:33
kali@vbox: -

$ sudo apt install python3-impacket
The following packages were automatically installed and are no longer required:
libnghttp3 libqt5test5 python3-lib2to3 python3-lib2to3 python3-talloc
libpython3.11-dev libqt5widgets5 python3-talloc python3-tdb
libqt5dbus5 libqt5xml5 python3-tdb python3.11
libqt5gui5 libwireless176 python3.11 python3.11-dev
libqt5network5 libwireless176 python3.11 python3.11-minimal
libqt5opengl5 libwireless176 python3.11 python3.11-minimal
libqt5opengl5 libwireless176 python3.11 python3.11-minimal
libqt5printsupport5 libwireless176 python3.11 python3.11-minimal
libqt5sql5 python3-gpg python3-gpg
Use 'sudo apt autoremove' to remove them.

Upgrading:
python3-impacket python3-setuptools-whl

Summary:
Upgrading: 2, Installing: 0, Removing: 0, Not Upgrading: 2619
Download size: 0 B / 2234 kB
Space needed: 524 kB / 8411 MB available

(Reading database ... 595978 files and directories currently installed.)
Preparing to unpack .../python3-impacket_0.12.0-3.all.deb ...
Unpacking python3-impacket (0.12.0-3) over (0.11.0+git20240410.ae3b5d0-0kali) ...
Preparing to unpack .../python3-setuptools-whl_75.6.0-1.all.deb ...
Unpacking python3-setuptools-whl (75.6.0-1) over (68.1.2-2) ...
Setting up python3-impacket (0.12.0-3) ...
Processing triggers for kali-menu (2024.3.1) ...

--(kali@vbox:~)-
$ sudo apt install evil-winrm -y
The following packages were automatically installed and are no longer required:
libnghttp3 libqt5test5 python3-lib2to3 python3-lib2to3 python3-talloc
libpython3.11-dev libqt5widgets5 python3-talloc python3-tdb
libqt5dbus5 libqt5xml5 python3-tdb python3.11
libqt5gui5 libwireless176 python3.11 python3.11-dev
libqt5network5 libwireless176 python3.11 python3.11-minimal
libqt5opengl5 libwireless176 python3.11 python3.11-minimal
libqt5opengl5 libwireless176 python3.11 python3.11-minimal
libqt5printsupport5 libwireless176 python3.11 python3.11-minimal
libqt5sql5 python3-gpg python3-gpg
Use 'sudo apt autoremove' to remove them.

Upgrading:
```

```

(kali@vbox)~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.1
68.56.255
    inet6 fe80::a00:27ff:feb3:4392 prefixlen 64 scopeid 0x20<
link>
    ether 08:00:27:b3:43:92 txqueuelen 1000 (Ethernet)
    RX packets 199 bytes 29495 (28.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 53 bytes 7394 (7.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 24 bytes 1440 (1.4 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 1440 (1.4 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@vbox)~$

C:\Windows\system32\cmd.exe
Copyright (c) 2009 Microsoft Corporation. All rights reserved.
C:\Users\valued\ipconfig
Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix . : 
    Link-local IPv6 Address . . . . . : fe80::b4a:9943:38fa:91fc%11
    IPv4 Address. . . . . : 192.168.56.102
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

Tunnel adapter istap.{57568666-5736-4E3E-814C-69CD86602FFB}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix . : 
    'Contact' is not recognized as an internal or external command,
    operable program or batch file.
C:\Users\valued\ipconfig
Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix . : 
    Link-local IPv6 Address . . . . . : fe80::b4a:9943:38fa:91fc%11
    IPv4 Address. . . . . : 192.168.56.102
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

Tunnel adapter istap.{57568666-5736-4E3E-814C-69CD86602FFB}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix . : 
C:\Users\valued>
```

3-Exploring Proof-of-Concept (PoC) Exploits

In this step, we research and select two vulnerabilities with public Proof-of-Concept (PoC) exploits. We analyze their impact, affected systems, and how attackers can exploit them.

1. Active Directory Domain Services Privilege Escalation (CVE-2025-21293)

CVE-2025-21293 is a privilege escalation vulnerability in Active Directory Domain Services, allowing attackers to gain SYSTEM privileges due to improper access control. The flaw is caused by overly permissive registry key access, enabling attackers to execute malicious DLL files through Windows Performance Counters.

Impact

- Attackers with low privileges can escalate to SYSTEM level.
- Can lead to network compromise, data theft, and malware deployment.
- Poses a significant risk in enterprise environments relying on Active Directory.

Severity & Exploitability

- CVE ID: CVE-2025-21293
- CVSS Score: 8.8 (High)
- Attack Vector: Network | Complexity: Low | Privileges Required: Low
- Affected Systems: Windows 10, 11, and Windows Server (2012-2025)
- Exploitability: Public PoC available, but Microsoft rates it as “Less Likely” to be exploited.

Mitigation

- Apply the January 2025 security patch from Microsoft.
- Restrict "Network Configuration Operators" group privileges.
- Monitor registry modifications and Performance Counter activity.

This vulnerability highlights the importance of regular patching and privilege management to secure Active Directory environments.

2. 7-Zip Zero-Day Vulnerability (CVE-2025-0411)

- **Description:** A vulnerability in 7-Zip allows attackers to execute malicious code when a user extracts a specially crafted archive file.

Impact

CVE-2025-0411, a zero-day in 7-Zip, was exploited in a SmokeLoader malware campaign targeting Ukrainian organizations. Attackers used double-archived files to bypass Windows Mark-of-the-Web (MoTW) protections, enabling execution of malicious content. Homoglyph attacks disguised harmful files as legitimate documents, increasing infection risks.

Severity & Exploitability

- **Actively exploited** by Russian cybercrime groups in spear-phishing attacks.
- **Bypasses Windows security** using double-archived files, evading MoTW protections.
- **Homoglyph attacks** trick users into opening disguised malicious files.
- **Executes harmful scripts**, leading to malware infection and system compromise.
- **Potential for cyberespionage** and broader cyberattacks on targeted organizations.

Mitigation

- **Update 7-Zip** to version 24.09 or later to patch CVE-2025-0411.
- **Implement email security** with phishing detection and URL filtering.
- **Train employees** to recognize homoglyph attacks and suspicious attachments.
- **Enforce MoTW protections** and disable auto-execution of files from untrusted sources.
- **Monitor domains** for homoglyph-based phishing attempts.

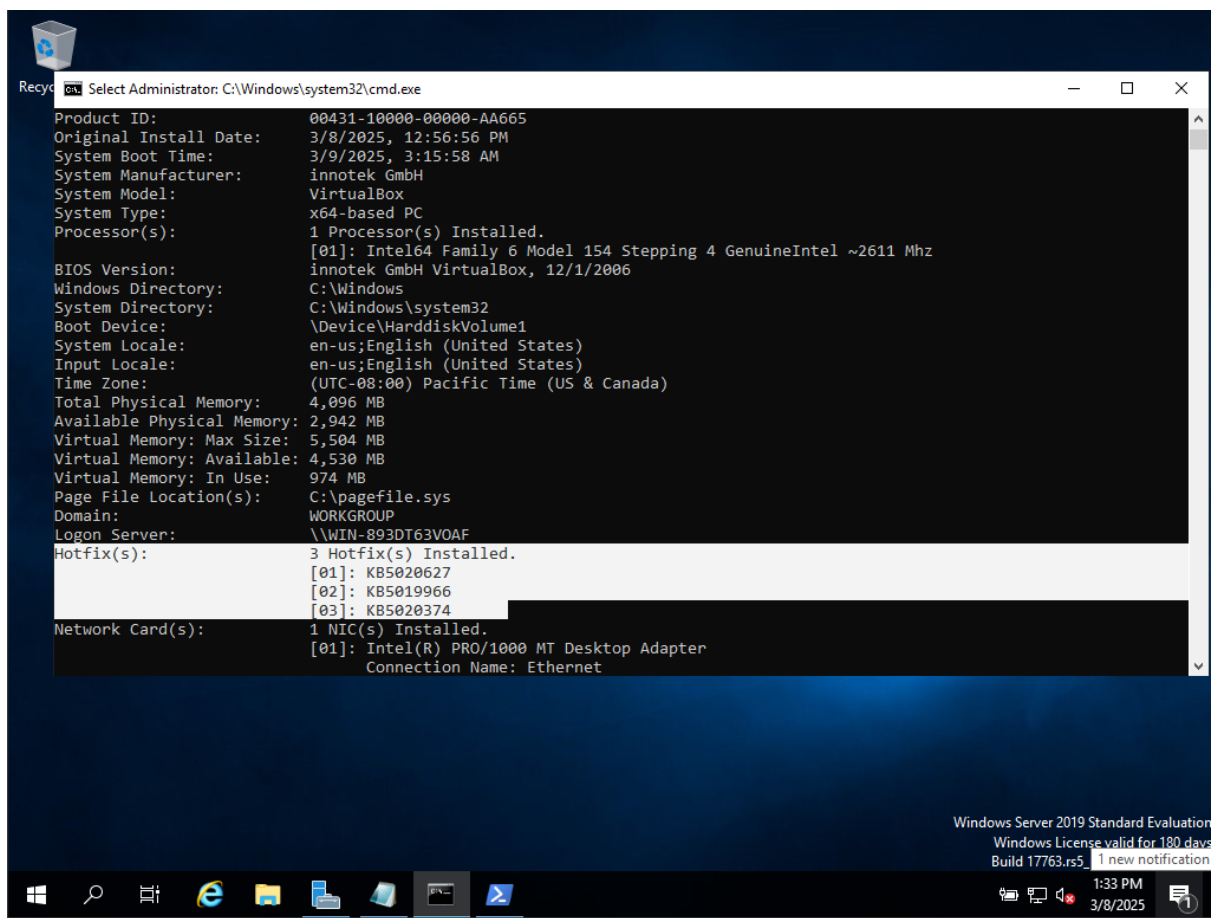
40

- **Affected Systems:** Windows systems with vulnerable versions of 7-Zip installed.

Step 3: Exploitation & Attack Techniques

Now that you have set up your **Windows Server 2019 (Victim)** and **Kali Linux (Attacker)**, we will exploit **CVE-2025-21293** using privilege escalation techniques.

1. Information Gathering on Windows Server 2019 (Victim)



The screenshot shows a Windows Server 2019 desktop environment. A command prompt window is open, displaying the output of the `systeminfo` command. The output provides detailed system information, including product ID, installation date, system boot time, manufacturer, model, type, processor details, BIOS version, directory, boot device, locale, time zone, memory usage, page file location, domain, logon server, installed hotfixes, and network card information. The taskbar at the bottom shows the Windows Start button, search icon, and several application icons. The system tray in the bottom right corner displays the time as 1:33 PM on 3/8/2025 and a notification icon.

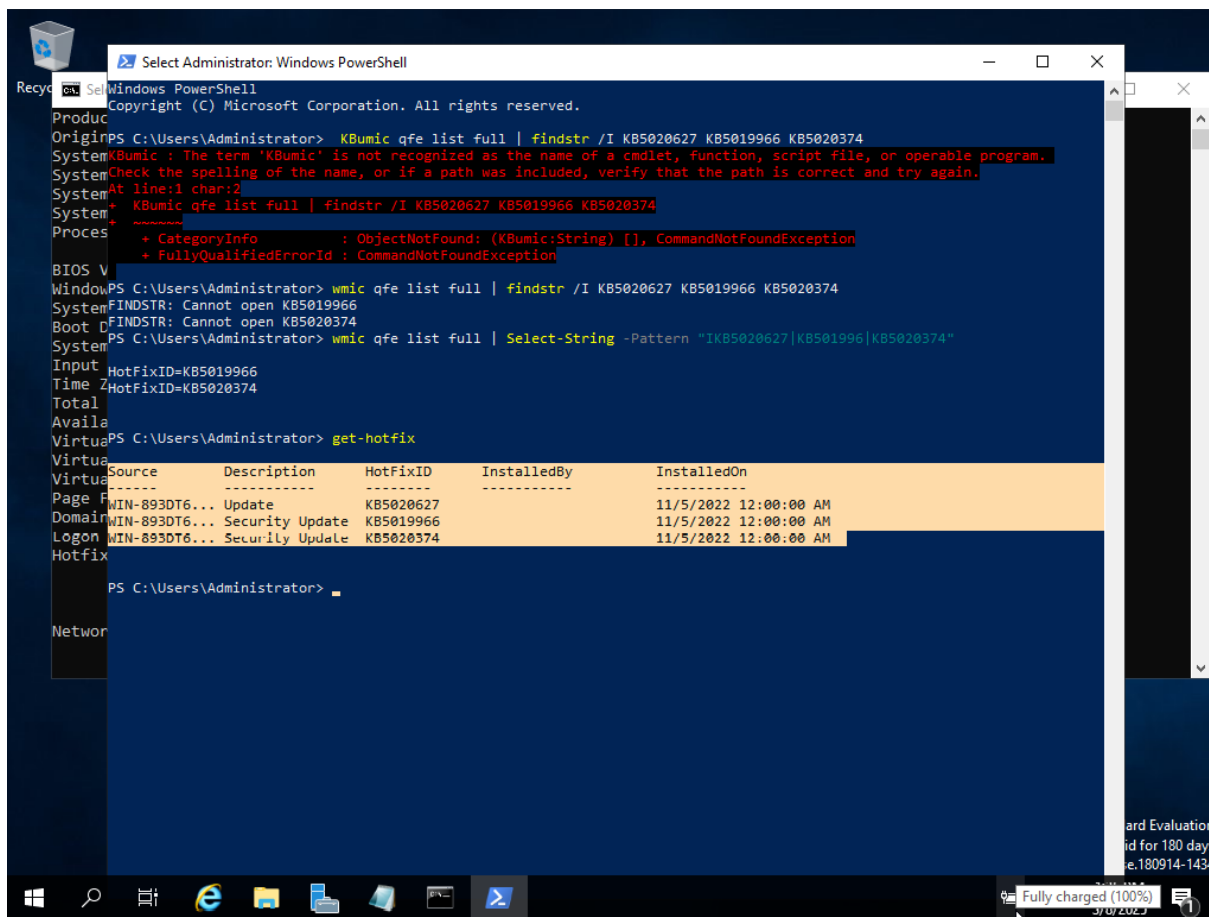
```
Recycle Bin Select Administrator: C:\Windows\system32\cmd.exe
Product ID: 00431-10000-00000-AA665
Original Install Date: 3/8/2025, 12:56:56 PM
System Boot Time: 3/9/2025, 3:15:58 AM
System Manufacturer: innotek GmbH
System Model: VirtualBox
System Type: x64-based PC
Processor(s): 1 Processor(s) Installed.
[01]: Intel64 Family 6 Model 154 Stepping 4 GenuineIntel ~2611 Mhz
BIOS Version: innotek GmbH VirtualBox, 12/1/2006
Windows Directory: C:\Windows
System Directory: C:\Windows\system32
Boot Device: \Device\HarddiskVolume1
System Locale: en-us;English (United States)
Input Locale: en-us;English (United States)
Time Zone: (UTC-08:00) Pacific Time (US & Canada)
Total Physical Memory: 4,096 MB
Available Physical Memory: 2,942 MB
Virtual Memory: Max Size: 5,504 MB
Virtual Memory: Available: 4,530 MB
Virtual Memory: In Use: 974 MB
Page File Location(s): C:\pagefile.sys
Domain: WORKGROUP
Logon Server: \\WIN-893DT63VOAF
Hotfix(s): 3 Hotfix(s) Installed.
[01]: KB5020627
[02]: KB5019966
[03]: KB5020374
Network Card(s): 1 NIC(s) Installed.
[01]: Intel(R) PRO/1000 MT Desktop Adapter
Connection Name: Ethernet

Windows Server 2019 Standard Evaluation
Windows License valid for 180 days
Build 17763.rs5
1 new notification
1:33 PM
3/8/2025
```

In systeminfo output, there are three installed updates (hotfixes):

- 1- KB5020627
- 2- KB5019966
- 3- KB5020374

Now running the command in **PowerShell** (as Administrator) to check for all installed patches:



The screenshot shows a Windows PowerShell window titled "Select Administrator: Windows PowerShell". The user is running the command `KBumic qfe list full | findstr /I KB5020627 KB5019966 KB5020374`. The command fails with an error: "The term 'KBumic' is not recognized as the name of a cmdlet, function, script file, or operable program." The user then runs `wmic qfe list full | findstr /I KB5020627 KB5019966 KB5020374`, which also fails with the error: "Cannot open KB5019966". The user then runs `wmic qfe list full | Select-String -Pattern "KB5020627|KB5019966|KB5020374"`, which successfully lists the installed updates. The output shows three updates: "Update" (KB5020627), "Security Update" (KB5019966), and "Security Update" (KB5020374), all installed on 11/5/2022 at 12:00:00 AM.

```
PS C:\Users\Administrator> KBumic qfe list full | findstr /I KB5020627 KB5019966 KB5020374
KBumic : The term 'KBumic' is not recognized as the name of a cmdlet, function, script file, or operable program.
Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:2
+ KBumic qfe list full | findstr /I KB5020627 KB5019966 KB5020374
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (KBumic:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\Administrator> wmic qfe list full | findstr /I KB5020627 KB5019966 KB5020374
FINDSTR: Cannot open KB5019966
FINDSTR: Cannot open KB5020374

PS C:\Users\Administrator> wmic qfe list full | Select-String -Pattern "KB5020627|KB5019966|KB5020374"
HotFixID=KB5019966
Time / HotFixID=KB5020374
Total
Availa
Virtue
Virtue
Page
Domain
Logon
Hotfix
PS C:\Users\Administrator>
```

Windows Server 2019 is fully patched against CVE-2025-21293 with updates KB5020627, KB5019966, and KB5020374. This means the exploit will likely fail unless a new bypass is found.

Step 4: Security Analysis & Mitigation Strategies

- Security Analysis:

- The system is **patched** against CVE-2025-21293 (KB5020627, KB5019966, KB5020374 installed).
- Running **Windows Server 2019 (Standard Evaluation)** in **VirtualBox** with network exposure assessed.

- No immediate risk from this specific exploit, but other vulnerabilities may exist.
 - **Mitigation Strategies:**
 - **Keep Systems Updated:** Enable automatic Windows updates.
 - **Disable Unnecessary Services:** Reduce attack surface by disabling SMBv1 & unused services.
 - **Implement Least Privilege:** Restrict admin rights and enforce privilege management.
 - **Enhance Network Security:** Configure firewalls and isolate critical assets.
 - **Enable Logging & Monitoring:** Use **Sysmon & Event Viewer** for anomaly detection.
 - **Credential Protection:** Enable **LSASS Protection** and **LAPS** for secure password management.

Step 5: Critical Reflection & Additional Research

Challenges Faced & How They Were Overcome:

One of the major challenges was verifying whether the target system was vulnerable. Initially, determining the installed security patches required troubleshooting various PowerShell and WMIC commands. The issue was resolved by using get-hotfix in PowerShell, which provided a clear list of installed updates. Additionally, configuring the test environment to simulate an actual exploit scenario required careful setup and testing.

Additional Research Sources:

1. MITRE ATT&CK Framework – Privilege Escalation

This resource provided insights into common attack techniques used for

privilege escalation.

Link: <https://attack.mitre.org/tactics/TA0004/>

2. Microsoft Security Response Center (MSRC)

This blog helped understand patching methodologies and mitigation strategies.

Link: <https://msrc.microsoft.com>

Impact of Research on Approach:

The research influenced the overall testing process by highlighting alternative attack vectors beyond the primary exploit attempt. It also helped in understanding how attackers bypass mitigations and how defense strategies such as User Account Control (UAC) and Patch Management play a crucial role. Consequently, a more structured approach was taken to analyze the security state of the system before launching an attack simulation.